

บทที่ 1

บทนำ

1.1 ความสำคัญและที่มาของโครงการ

เนื่องจากการเกิดบัฟเฟอร์โอเวอร์โฟลว์ จะเกิดขึ้นเมื่อ ผู้ใช้หรือโปรแกรมเมอร์ อินพุตข้อมูลเข้าไปในบัฟเฟอร์ มากกว่าที่ขนาดของบัฟเฟอร์ได้ถูกจัดสรรไว้ ทำให้อินพุต ข้อมูลเกิดการล้นหรือ โอเวอร์โฟลว์ขึ้น พฤติกรรมนี้มักเกี่ยวข้องกับฟังก์ชันในภาษา C ตัวอย่างเช่น strcpy() , strcat() และ sprintf() เป็นต้น อย่างไรก็ตาม พฤติกรรมนี้สามารถถูก นำมาใช้เพื่อลักลอบเจาะไปที่ระบบเป้าหมายได้ และด้วยเหตุผลนี้โปรแกรมต่างๆที่เขียนขึ้นมา โดยปราศจากการคำนึงถึงเรื่องความปลอดภัยที่จะส่งผลร้ายตามมาต่อทั้งโปรแกรมของตนเอง และระบบปฏิบัติการที่ใช้จึงเกิดขึ้นได้เสมอ

ดังนั้นเราจึงควรศึกษาวิธีการเขียนโปรแกรมที่ดี เพื่อไม่ให้ก่อให้เกิดเหตุการณ์เหล่านั้นได้ โดยขั้นตอนการศึกษานั้นเราต้องศึกษาตั้งแต่การโจมตี เพื่อเรียนรู้จุดอ่อนของระบบเพื่อที่จะเจาะ เข้าไปได้ และเมื่อทราบถึงกระบวนการบุกรุกแล้ว ก็เป็นขั้นตอนการป้องกันเพื่อไม่ให้ก่อให้เกิด เหตุการณ์นั้นได้อีกได้ในอนาคต โดยระบบปฏิบัติการที่ใช้ในการศึกษาคือ Fedora Core

นอกจากนั้นการศึกษาเรื่องของภัย และการป้องกันภัยจากอินเทอร์เน็ตก็เป็นเรื่องสำคัญ อีกเรื่องหนึ่งเพราะ ภัยที่มาจากอินเทอร์เน็ตนั้น ก่อให้เกิดผลกระทบที่ร้ายแรงมากในปัจจุบัน และ บางภัยก็มีส่วนเกี่ยวข้องกับเรื่องของ Buffer Overflow ที่ได้ศึกษาในข้างต้นด้วย เพราะฉะนั้นจึงควร ศึกษาและหาแนวทางป้องกันภัยต่างๆให้เกิดขึ้นน้อยที่สุดเท่าที่จะเป็นไปได้ในอนาคต

1.2 วัตถุประสงค์ของโครงการ

1. เพื่อศึกษาแนวคิดและเครื่องมือบุกรุกช่องโหว่ทางซอฟต์แวร์โดยเทคนิคบัฟเฟอร์โอเวอร์ โฟลว์และคอมมานด์อินเจกชัน
2. เพื่อศึกษาวิธีการป้องกันการบุกรุกช่องโหว่โดยวิธีต่างๆ
3. เพื่อพัฒนาเครื่องมือบุกรุกช่องโหว่ด้วยเทคนิคต่างๆ
4. เพื่อพัฒนาเทคโนโลยีระบบรักษาความปลอดภัยให้กับระบบปฏิบัติการ
5. เพื่อจัดทำเอกสารคู่มือการป้องกันภัยจากอินเทอร์เน็ต และการเขียนโปรแกรมให้ถูกวิธี เพื่อป้องกันการบุกรุก

1.3 ขอบเขตของโครงการ

ในปฏิญานิพนธ์ฉบับนี้ได้นำเสนอวิธีการป้องกันการบุกรุกช่องโหว่ทางซอฟต์แวร์ โดยแบ่งหัวข้อหลักๆออกเป็นสองส่วนคือส่วนป้องกันการบุกรุกทางซอฟต์แวร์บนระบบปฏิบัติการ และส่วนของป้องกันการบุกรุกบนเว็บไซต์ โดยส่วนป้องกันการบุกรุกทางซอฟต์แวร์บนระบบปฏิบัติการนั้นพัฒนาโปรแกรมสองโปรแกรมคือ Lancelot Scan และ Lancelot Guard และส่วนของป้องกันการบุกรุกบนเว็บไซต์นั้นจัดทำเว็บไซต์เพื่อจำลองสถานการณ์การบุกรุก และจัดทำเอกสารคู่มือการป้องกันภัยจากอินเทอร์เน็ต และการเขียนโปรแกรมให้ถูกวิธีเพื่อป้องกันการบุกรุก

1.4 วิธีการดำเนินการ

1. ศึกษารายละเอียดต่างๆของโปรเจค

- ศึกษารูปแบบการโจมตีรูปแบบต่างๆ (Attack Patterns) ประกอบด้วย
 - Buffer Overflow รูปแบบต่างๆ
 - SQL Injection
 - Java Script Injection
 - Session Hijacking
 - Cross-Site Scripting
- ศึกษาการป้องกันการโจมตีด้วยวิธี Stack Guard หรือ Stack Overflow Detection และ API Wrapper

2. การทดลองการทำงานของ Code

- ทดลองโปรแกรมการโจมตีแบบต่างๆ
- ทดลองโปรแกรมป้องกันการโจมตีด้วยวิธี Stack Guard และ API Wrapper
- ทดลองโปรแกรมการโจมตี application บนฝั่ง Server และ Client

3. Programming Coding

- เขียนโปรแกรมป้องกันการโจมตีด้วยวิธี API Wrapper และ Stack Guard
- เขียนโปรแกรมการโจมตี application บนฝั่ง Server
- เขียนโปรแกรมการโจมตี application บนฝั่ง Client

4. จัดทำเอกสารคู่มือการป้องกันภัยจากอินเทอร์เน็ต และการเขียนโปรแกรมให้ถูกวิธีเพื่อป้องกันการบุกรุก

1.5 ประโยชน์ที่คาดว่าจะได้รับ

1. ได้รับความรู้ความเข้าใจเกี่ยวกับการทำงานเกี่ยวกับระบบปฏิบัติการ Fedora Core
2. ได้รับความรู้ความเข้าใจเกี่ยวกับการบุกรุกช่องโหว่ทางซอฟต์แวร์
3. ได้รับความรู้ความเข้าใจเกี่ยวกับการป้องกันการบุกรุกช่องโหว่ทางซอฟต์แวร์
4. ได้เอกสารคู่มือการป้องกันภัยจากอินเทอร์เน็ต และการเขียนโปรแกรมให้ถูกวิธีเพื่อป้องกันการบุกรุก

1.6 ส่วนประกอบของปริญญานิพนธ์

ปริญญานิพนธ์ฉบับนี้ได้แบ่งเนื้อหาออกเป็น 6 บท 2 ภาคผนวกด้วยกันคือ

บทที่ 1 กล่าวถึงความสำคัญและที่มาของโครงการ วัตถุประสงค์ของโครงการ ขอบเขตของโครงการ วิธีการดำเนินการ ประโยชน์ที่คาดว่าจะได้รับ และส่วนประกอบของปริญญานิพนธ์

บทที่ 2 กล่าวถึงเรื่องของการเกิด Buffer Overflow โดยอธิบายเนื้อหาตั้งแต่การจัดการหน่วยความจำ การเรียกฟังก์ชัน ส่วนที่เสี่ยงต่อการถูกโจมตี การเกิด Buffer Overflow รวมถึง การเกิด Stack Overflow และ Heap Overflow

บทที่ 3 กล่าวถึงการป้องกันการเกิด Buffer Overflow ซึ่งประกอบไปด้วยการวิเคราะห์โค้ด ซึ่งรวมถึงฟังก์ชันที่เสี่ยงต่อการถูกโจมตี การเขียนโปรแกรมอย่างไรให้ถูกหลัก และรายละเอียดของโปรแกรม Lancelot Scan และ Lancelot Guard ที่ได้พัฒนาขึ้นมา

บทที่ 4 กล่าวถึงภัย และการป้องกันภัยจากอินเทอร์เน็ตซึ่งประกอบไปด้วยภัยที่เกิดขึ้นบ่อยครั้งในปัจจุบันคือ SQL Injection, Javascript Injection, Cross-Site Scripting และ Session Hijacking โดยเนื้อหาในแต่ละส่วนได้อธิบายถึงการเกิดภัยนั้นๆ และกรป้องกันด้วยวิธีต่างๆ

บทที่ 5 กล่าวถึงการทดลองและผลการทดลอง โดยได้เขียนการทดลอง และผลการทดลองสำหรับโปรแกรม Lancelot Scan และ Lancelot Guard รวมถึงการทดสอบสถานการณ์สมมติการบุกรุกเว็บไซต์ด้วย

บทที่ 6 เป็นบทวิจารณ์และสรุป ซึ่งกล่าวถึงบทสรุปของโครงการ วิจารณ์สิ่งที่ได้รับจากโครงการ และข้อเสนอแนะสำหรับเป็นแนวทางในการพัฒนาต่อ

ภาคผนวก ก. เป็นตัวอย่างสถานการณ์สมมติภัยบนเว็บไซต์ ซึ่งได้อธิบาย รวมถึงเฉลยวิธีการบุกรุกเว็บไซต์จากการทดลองในบทที่ 5

ภาคผนวก ข. เป็นวิธีปิดการทำงานของ Script บน Microsoft Internet Explorer และ Mozilla Firefox